PRADITA University

IT40813 · IT Governance, Risk & Compliance

Kelangsungan Bisnis dan Ketahanan Operasional

Pertemuan 10

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Tanggung Jawab Direksi
3. Sistem Manajemen
4. Analisis Dampak Bisnis
5. Strategi Kelangsungan
6. Insiden dan Krisis
7. Latihan dan Pengujian
8. Penutup

PRADITA University

Server hidup pukul 14.00. Mengapa antrean baru habis pukul 20.00?

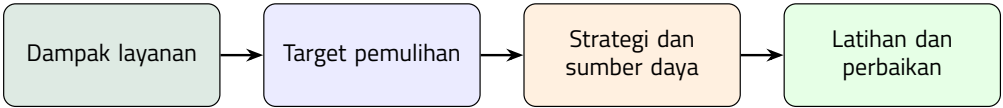
Tujuan Pembelajaran

- Melakukan BIA (*Business Impact Analysis*) untuk menentukan layanan kritis beserta RTO dan RPO-nya.
- Memilih strategi kelangsungan yang sepadan dengan dampak dan biaya.
- Merancang skenario latihan krisis yang menguji keputusan, bukan hanya teknologi.

Masalah: SIMRS Berhenti Enam Jam

- Misalkan SIMRS rumah sakit Bekasi berhenti dari pukul 08.00 sampai 14.00.
- Petugas menerima pasien dengan kertas, tetapi tidak dapat membaca obat dari unit lain.
- Pukul 14.00 server hidup. Antrean dan catatan kertas belum selesai.
- Pekerjaan yang ditutup: DSS04 dari Bab 4, 144 uji dari Bab 3, R-05 dari Bab 5.
- Hasil kerja: BIA, strategi, dan skenario latihan untuk tonggak C3.

Alur Keputusan



Teknologi dipilih sesudah target layanan disepakati, bukan sebelumnya. Rujukan utama: ISO 22301:2019, NIST SP 800-34 Rev. 1, Peraturan BSSN 1/2024 dan 2/2024, DORA sebagai pembanding.

Diagram Konsep Bab 10

IT40813 / BAB 10 / DIAGRAM KONSEP

Kelangsungan layanan memerlukan jalur bisnis dan teknologi



Server hidup belum menjamin layanan pasien pulih. Tabletop menguji keputusan; restore teknis membuktikan kemampuan pemulihan.

Tiga Disiplin pada Satu Kejadian

Disiplin	Pertanyaan	Pemimpin	Bukti selesai
Manajemen insiden	Apa yang terjadi dan bagaimana dibatasi?	Kepala operasi TI	Kronologi, alasan isolasi, hasil pembatasan
Kelangsungan bisnis	Bagaimana pasien tetap dilayani dengan aman?	Direktur rumah sakit dan pemilik layanan	Kapasitas minimum, batas aman
Pemulihan bencana	Kapan sistem dan data kembali?	Kepala operasi TI	Waktu *restore*, titik data, verifikasi

Analogi toko tanpa listrik: teknisi memperbaiki instalasi, pengelola mengatur transaksi manual, pemilik memutuskan kapan operasi dihentikan. Laporan “pulih dalam 90 menit” hanya menjawab satu pertanyaan.

Siapa Memutuskan

Peran	Keputusan	Bukti
Direksi	Toleransi gangguan dan biaya	Persetujuan batas dan anggaran
Direktur pelayanan	Layanan minimum lintas fasilitas, pengalihan	Catatan pengalihan
Direktur rumah sakit	Aktivasi operasi manual di lokasi	Waktu aktivasi dan alasannya
Pemilik layanan	Kapasitas minimum yang aman	Prosedur manual tervalidasi
Kepala operasi TI	Urutan pemulihan sistem	Hasil uji pemulihan

Peraturan BSSN 1/2024 Pasal 18 ayat (3): rencana tanggap insiden dan rencana keberlangsungan kegiatan disetujui pimpinan organisasi.

Keputusan yang Tidak Diserahkan kepada Teknisi

- Rp120 juta per tahun cukup diputus komite pengarah TI.
- Rp480 juta melewati batas Rp400 juta, sehingga naik ke direksi.
- Farmasi punya stok, tetapi riwayat obat tidak terbaca. Transaksi manual dibatasi pada resep yang dapat diverifikasi. Kaitannya R-11.
- Bab 5: gangguan pendaftaran 2 jam per bulan. Enam jam memakai 3 kali batas itu.
- Kegagalan mencapai target dieskalasikan sebagai risiko.

Membandingkan Dua Aturan

PRADITA University

Pokok	BSSN 1/2024	DORA (pembanding)	Pilihan Medikara (misalkan)
Pimpinan	Pasal 18 ayat (3): rencana disetujui pimpinan	Pasal 5 ayat (2): tanggung jawab akhir pada badan pengelola	Direksi mengesahkan BIA dan rencana
Target pulih	Lampiran A: capaian dari waktu, jumlah data, fungsi	Pasal 12 ayat (6): target waktu dan titik pulih per fungsi	MTPD, RTO, RPO, kapasitas minimum per layanan
Cadangan	Pasal 18 ayat (3) huruf e: memahami penggunaan rekam cadang	Pasal 12 ayat (3): sistem terpisah secara fisik dan logis	Cadangan dan akun terpisah; K-02
Frekuensi uji	Pasal 26: berkala; paling sedikit 1 kali dalam 2 tahun bagi penyelenggara IIV	Pasal 11 ayat (6): paling sedikit setahun sekali	144 uji dan 5 *tabletop* per tahun

DORA berlaku bagi sektor keuangan Uni Eropa, bukan bagi Medikara.

ISO 22301: Sistem, Bukan Resep Perangkat

PRADITA University

- Lingkup, konteks, tanggung jawab, analisis, strategi, rencana, uji, dan perbaikan.
- Analogi latihan kebakaran: peta rapi tidak membuktikan pintu darurat dapat dibuka.
- Latihan pada 1 dari 5 rumah sakit dilaporkan 20 persen, atau 1 dari 36 fasilitas sekitar 2,8 persen.
- K-02 meminta tempat berbeda. Alamat berbeda belum tentu mengurangi ancaman bersama.
- Naskah ISO berbayar. Rincian klausul dicocokkan ke naskah berlisensi sebelum audit.

Siklus Pengelolaan Kelangsungan (Misalkan)

PRADITA University

Tahap	Pertanyaan	Bukti minimum	Contoh Medikara
Rencana	Layanan apa yang dipertahankan?	Ruang lingkup dan BIA	36 baris BIA, disahkan direksi
Pelaksanaan	Siapa menjalankan alternatif?	Rencana dan daftar kontak	Prosedur korporat dengan 36 lampiran
Evaluasi	Target tercapai atau belum?	Catatan latihan	144 uji dan 5 *tabletop* per tahun
Perbaikan	Celah mana yang ditutup?	Tindakan, pemilik, tenggat	Uji ulang masuk register R-05

DSS04: Delapan Praktik (Misalkan)

Praktik	Inti praktik (diringkas)	Bukti Medikara
DSS04.01	Kebijakan, tujuan, dan ruang lingkup	Ruang lingkup 36 fasilitas disahkan
DSS04.02	Menjaga ketahanan bisnis	BIA 36 baris dan pilihan strategi
DSS04.03	Mengembangkan dan menerapkan respons	Prosedur korporat, 36 lampiran
DSS04.04	Melatih, menguji, dan meninjau rencana	144 uji dan 5 *tabletop*
DSS04.05	Meninjau, memelihara, dan memperbaiki	Tindakan, pemilik, tenggat, uji ulang
DSS04.06	Pelatihan rencana	Petugas manual dilatih dan dicatat
DSS04.07	Mengelola pengaturan cadangan	KB-08, K-02, cadangan dan akun terpisah
DSS04.08	Tinjauan sesudah pemulihan	Rekonsiliasi disahkan kepala rekam medis

Target DSS04: Tingkat 3

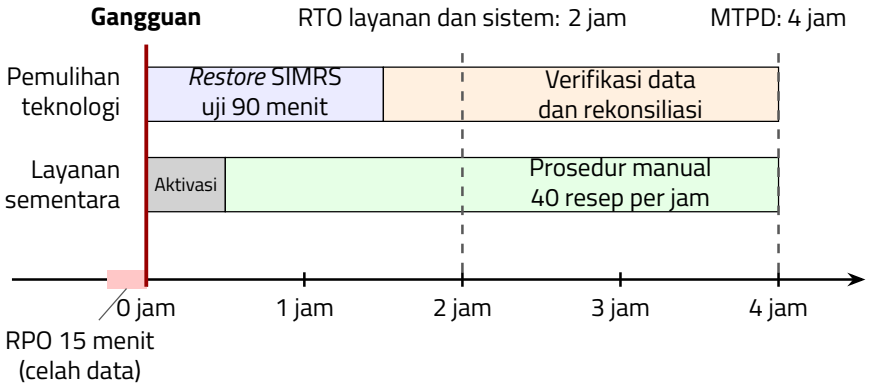
- 36 prosedur terpisah memakan 288 jam per tahun. Satu korporat dengan 36 lampiran memakan 112 jam. Selisih 176 jam, atau Rp10,56 juta.
- Tingkat 4 menambah Rp180 juta, sedangkan sisa harapan kerugian R-05 hanya Rp40 juta.
- Rancangan Bab 8 naik dari Rp600 juta menjadi Rp720 juta per tahun: 4 kali Rp120 juta ditambah 4 kali Rp60 juta.
- Keputusan tetap di direksi. Kode target baru: T-24.
- Rp120 juta hanya kerja proses. Biaya solusi dihitung terpisah.

Empat Ukuran

- MTPD: batas setelah dampak gangguan tidak dapat diterima.
- RTO: target waktu pemulihan pada kapasitas yang disepakati.
- RPO: titik data yang harus dapat dipulihkan.
- MBCO: kapasitas minimum layanan. Bab ini menulisnya kapasitas minimum.
- NIST: RTO biasanya lebih pendek daripada MTD, dan RPO bukan bagian MTD.

Analogi kas: kasir jalan lagi dalam 2 jam, buku terakhir 15 menit sebelum gangguan.

Letak Keempat Ukuran pada Farmasi



Angka farmasi pada satu rumah sakit (pengandaian). RPO berada sebelum gangguan, sedangkan RTO dan MTPD berada sesudahnya. Uji 90 menit berada di bawah RTO sistem 120 menit.

Langkah Pertama: Dampak Menurut Waktu

Layanan	1 jam	4 jam	6 jam	12 jam	24 jam	48 jam	Cedera berat sejak
IGD	3	**4**	5	5	5	5	1 jam
Farmasi	2	**4**	4	5	5	5	4 jam
Laboratorium	2	**4**	4	5	5	5	4 jam
Pendaftaran	2	3	**4**	4	5	5	Tidak langsung
Telekonsultasi	1	2	2	**4**	4	5	Tidak langsung
Klaim BPJS	1	1	1	2	3	**4**	Tidak ada

Skala dampak Bab 5. MTPD adalah titik waktu pertama bernilai 4 atau lebih. BIA 36 baris memakan 216 jam, atau Rp12,96 juta.

Contoh Hasil BIA Bekasi (Misalkan)

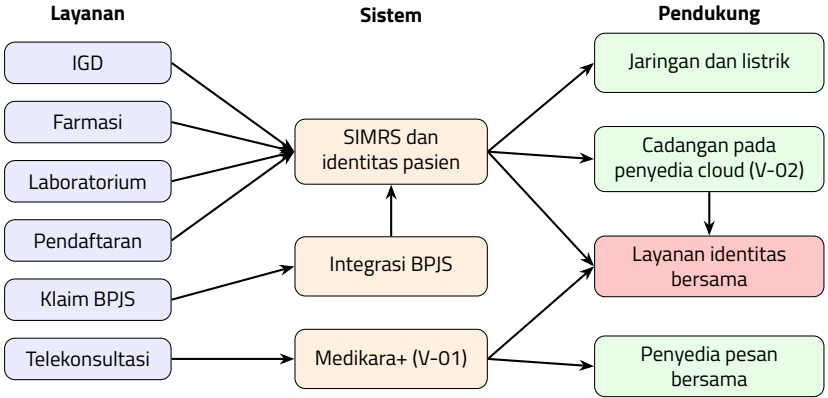
Layanan	Normal	Minimum	MTPD	RTO	RPO
IGD	6 pasien per jam	6 pasien per jam	4 jam	15 menit	5 menit
Farmasi	100 resep per jam	40 resep per jam	4 jam	2 jam	15 menit
Laboratorium	60 hasil per jam	20 hasil per jam	4 jam	2 jam	15 menit
Pendaftaran	40 pasien per jam	20 pasien per jam	6 jam	90 menit	30 menit
Telekonsultasi	40 konsultasi per jam	10 konsultasi per jam	12 jam	6 jam	60 menit
Klaim BPJS	300 klaim per hari	100 klaim per hari	48 jam	24 jam	4 jam

Angka klinis bukan standar pelayanan dan harus divalidasi pihak yang berwenang.

Dua Hal yang Sering Tertukar

- RTO layanan: kapan pasien dilayani lagi pada kapasitas minimum, lewat jalur apa pun.
- RTO sistem: kapan SIMRS dan datanya kembali. Di sini $240 - 120 = 120$ menit.
- Uji 150 menit gagal 30 menit, walaupun formulir kertas berjalan sejak menit ke-30.
- Batas Bab 5 kumulatif, 2 jam per bulan. MTPD per kejadian, 6 jam pada pendaftaran. RTO pendaftaran 90 menit menyisakan 30 menit.
- Cadangan malam: sampai 1.200 resep hilang, 60 jam kerja. RPO 15 menit: 25 resep, 75 menit.

Langkah Kedua: Ketergantungan



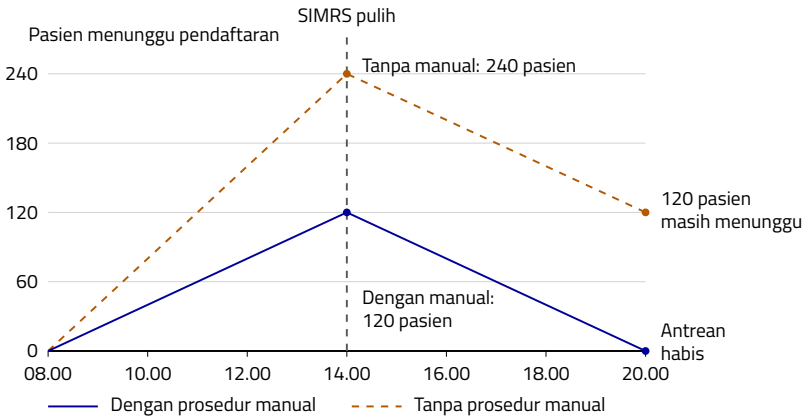
Panah berarti bergantung pada. Merah: titik kegagalan bersama menurut peta Bab 9. Rancangan target, seluruhnya pengandaian dan perlu dibuktikan lewat kontrak serta uji.

Dua Hitungan Ketergantungan dan Prioritas

PRADITA University

- Layanan identitas dijanjikan pulih 8 jam. *Restore* 90 menit baru dapat dimulai sesudahnya: 9,5 jam, atau 5,5 jam di atas MTPD.
- 144 uji dengan akun yang sama tidak akan menemukan selisih ini.
- Kontrak V-01 24 jam, RTO telekonsultasi 6 jam. Selisih 18 jam ditutup telepon atau tawar ulang. Sekitar 933 janji temu terganggu.
- Prioritas: identitas pasien, lalu IGD, farmasi, dan laboratorium.
- Disusul pendaftaran, telekonsultasi, dan klaim BPJS.

Kasus Medikara: Antrean Enam Jam di Bekasi



Pengandaian rumah sakit Bekasi: 40 pasien datang per jam, manual 20 per jam, tanpa manual 0 per jam, sesudah SIMRS pulih 60 per jam.

Kasus Medikara: Membaca Hitungan

PRADITA University

- Enam jam: 240 pasien datang, 120 terlayani, 120 menunggu.
- Sesudah pulih, antrean turun 20 per jam dan habis pukul 20.00. Tanpa manual, masih tersisa 120 pasien.
- Rekonsiliasi: 120 pendaftaran 10 jam, 240 resep 12 jam, total 22 jam kerja.
- Enam jam melewati MTPD farmasi, IGD, dan laboratorium sebesar 2 jam.
- Pengalihan sebagian layanan semestinya mulai sejak jam ke-4.

Dua Jalur Strategi (Misalkan)

Layanan	Rencana operasional	Rencana pemulihan	Risiko sisa
IGD	Triase kertas, gelang identitas, pengalihan	Salinan baca saja riwayat alergi, KB-04	Data lintas unit lambat; R-11
Farmasi	Resep kertas yang dapat diverifikasi	Cadangan terpisah, pemulihan prioritas	Resep tanpa riwayat tertahan
Laboratorium	Hasil kritis lewat telepon, pembacaan ulang	Pemulihan antarmuka alat	Salah identitas
Pendaftaran	Formulir kertas, daftar jadwal harian	Identitas pasien lebih dulu	Antrean, rekonsiliasi
Telekonsultasi	Telepon, 10 konsultasi per jam	Kontrak V-01, uji ekspor tahunan	Janji temu tertunda
Klaim BPJS	Tunda, lalu 100 klaim per hari	Pulih sesudah layanan klinis	Penumpukan administrasi

Orang, data, tempat, dan vendor menghasilkan layanan sementara dan pemulihan teknologi.

Membaca Penelitian: Prosedur Manual

PRADITA University

- Larsen dan rekan (2018): 76 dari 80.381 laporan insiden menyebut rekam medis elektronik yang berhenti.
- 37 laporan (48,7 persen) laboratorium; 11 laporan (14,5 persen) obat.
- 35 laporan (46 persen): prosedur tidak diikuti atau tidak tersedia.
- 21 laporan (27,6 persen): prosedur berjalan.
- Bukan peluang Medikara. Nilainya pada arah perhatian: laboratorium, obat, identitas.

Replikasi dan Cadangan

PRADITA University

- Replikasi menyalin perubahan dengan cepat, termasuk kerusakan.
- Cadangan terpisah menyimpan titik waktu, tetapi pemulihannya dapat lebih lambat.
- Analogi: mesin fotokopi ke kantor cabang dan arsip di lemari terkunci.
- Replikasi 5 menit: RPO 5 menit berlaku untuk kegagalan perangkat, bukan *ransomware*.
- Akun yang sama dapat merusak kedua salinan. Tempat berbeda belum cukup bila aksesnya sama.

Tiga Opsi untuk Lima Rumah Sakit per Tahun (Misalkan)

PRADITA University

Ukuran	Target	A. Manual terkontrol	B. Manual dan pemulihan prioritas	C. Replikasi aktif
Biaya per tahun		Rp120 juta	Rp480 juta	Rp6 miliar
Kapasitas manual farmasi	40 per jam	20 per jam	40 per jam	40 per jam
SIMRS pulih	120 menit	480 menit	90 menit	Mendekati nol; 90 menit bila data rusak
Titik data	15 menit	Sampai 24 jam	10 menit	Mendekati nol; 10 menit bila data rusak
Harapan kerugian R-05		Rp200 juta	Rp40 juta	Rp40 juta
Biaya ditambah kerugian		Rp320 juta	Rp520 juta	Rp6,04 miliar
Hasil		Ditolak	Layak bersyarat	Ditolak

Pilihan A dan B: Tradeoff yang Nyata

PRADITA University

- A lebih murah Rp200 juta per tahun. Tambahan Rp360 juta hanya menurunkan harapan kerugian Rp160 juta.
- A melanggar batas 2 persen dan kapasitas minimum. Selisih itu harga memenuhi batas.
- C menelan 12,5 kali B dan melewati batas direksi Rp5 miliar.
- Persetujuan bersyarat: Rp360 juta dua tahap, 5 dari 5 rumah sakit lulus uji, 9 uji akun terpisah berhasil.
- Harapan kerugian tidak mengukur cedera pasien.

Tiga Tingkat Eskalasi



Pemicu krisis organisasi adalah pengandaian Medikara. Definisi dan penetapan Krisis Siber mengikuti Peraturan BSSN 2/2024 Pasal 1 angka 3 dan Pasal 13 ayat (2).

Rumah sakit tidak dapat menyatakan Krisis Siber. Peringatan dini: PSE menindaklanjuti dan melapor setiap 2 jam, atau 6 laporan dalam 12 jam layanan.

Komunikasi dan Pemberitahuan

PRADITA University

- Sampaikan yang diketahui, dampak layanan, tindakan sementara, dan waktu pembaruan.
- Pukul 09.00: cakupan dan jadwal diumumkan, penyebab yang belum terverifikasi tidak.
- Selasa 09.15 indikasi data keluar. Jam ke-60: Kamis 21.15.
- Batas terluar 3×24 jam: Jumat 09.15. K-05 vendor 12 jam: Selasa 21.15.
- SIMRS pulih pukul 14.00 tidak menggeser ketiga batas itu.

Catatan Keputusan Krisis (Misalkan)

Keputusan	Pemilik	Target waktu	Bukti
Isolasi sistem	Kepala operasi TI	15 menit	Alasan dan waktu isolasi
Operasi manual	Direktur rumah sakit	20 menit	Kapasitas dan batas aman
Pengalihan pasien	Direktur pelayanan	30 menit	Fasilitas penerima, kapasitas
Pernyataan publik	Direktur utama	60 menit	Fakta terverifikasi, jadwal
Pemberitahuan	Fungsi hukum, petugas pelindungan data	Jam ke-60, terluar 3×24 jam	Dasar, penerima, waktu kirim

Membaca Penelitian: Pengalihan Pasien

PRADITA University

- Dameff dan rekan (2023): serangan Mei 2021 pada 4 rumah sakit; 2 IGD tetangga ditelaah.
- Pasien harian 218,4 menjadi 251,4 (15,1 persen); ambulans 1.741 menjadi 2.354 (35,2 persen).
- Median waktu masuk ruang periksa 21 menjadi 31 menit; pulang sebelum dilayani 158 menjadi 360.
- Observasional pada satu wilayah. Angkanya tidak disalin ke Medikara.
- Misalkan IGD Bekasi mengalihkan 3 pasien per jam ke 2 IGD: tiap penerima naik 25 persen.

Jenis Pengujian dan Batas Buktinya

Metode	Yang diuji	Yang belum dibuktikan
Tabletop	Wewenang dan keputusan	Kecepatan pemulihan server
Latihan fungsional	Peran dan prosedur satu fungsi	Fungsi lain, data lintas unit
Uji teknis	Waktu dan integritas data	Kesiapan seluruh petugas
Latihan terpadu	Layanan minimum lintas unit	Semua skenario masa depan

Uji 150 menit terhadap RTO 120 menit: selisih 30 menit masuk register dan IT40713. Keputusan manual 35 menit terhadap target 20 menit: selisih 15 menit menjadi temuan.

Mengisi 144 Uji Pemulihan

Triwulan pertama	Uji	Lulus	Lewat RTO	Data gagal	Persen
5 rumah sakit	5	3	1	1	60,0
31 fasilitas lain	31	26	4	1	83,9
Total	36	29	5	2	80,6

- 144 uji dan 432 jam tetap. Hanya 20 uji menyentuh SIMRS rumah sakit.
- 108 uji biasa dan 36 uji akun terpisah, atau 25 persen.
- Dua data gagal berasal dari 9 uji akun terpisah. Angka lulus bukan peluang R-05.

Skenario Tabletop dan Contoh Hasil (Misalkan)

Waktu	Informasi dan keputusan	Pemilik	Target	Aktual
08.00	SIMRS tidak dapat dibuka. Siapa memimpin?	Kepala operasi TI	10	8
08.15	Berkas terenkripsi di tiga unit. Apa yang diisolasi?	Kepala operasi TI	15	15
08.15	Layanan terganggu. Kapan manual aktif?	Direktur rumah sakit	20	35
08.30	Cadangan belum tervalidasi. Strategi apa dipilih?	Direktur pelayanan	30	25
08.45	Vendor tidak dapat dihubungi. Kapan jalur lain aktif?	Kepala operasi TI	15	40
09.00	Media menanyakan kebocoran. Apa yang diumumkan?	Direktur utama	60	50
09.15	Indikasi data keluar. Kapan proses pemberitahuan dimulai?	Fungsi hukum	30	45

Diskusi 45 menit, evaluasi 15 menit. Tanpa menyentuh sistem nyata dan tanpa data pasien.

Kasus Medikara: Membaca Hasil Tabletop

PRADITA University

- Empat dari tujuh keputusan tepat waktu, sekitar 57 persen. Total terlambat 55 menit.
- Manual +15: daftar kewenangan. Vendor +25: satu nomor kontak. Hukum +15: baru diundang.
- Tindakan dalam 14 sampai 30 hari, uji ulang dalam 60 hari.
- Keputusan 08.30 tepat waktu, tetapi memakai cadangan yang belum tervalidasi.
- Lima rumah sakit: 35 jam per tahun. Beban Bab 8 tahun pertama 1.443 jam, sekitar 0,75 orang penuh waktu.

Aktivitas: BIA dan Strategi Kelangsungan Layanan

PRADITA University

- Nilai dampak 5 sampai 7 layanan. Tetapkan MTPD, RTO, RPO, dan kapasitas minimum.
- Bandingkan strategi dua layanan kritis menurut biaya, asumsi, dan risiko sisa.
- Jalankan *tabletop*. Catat waktu, dasar bukti, tindakan, dan uji ulang.
- Peran: kesehatan atau operasional, analis teknologi, analis risiko, pemilik konteks.
- Luaran masuk C3, selaras dengan IT40713. Berkas: `sources/chapter10/README.md`.

Ringkasan

- Direksi menetapkan toleransi. DSS04 tingkat 3, rancangan Bab 8 menjadi Rp720 juta.
- BIA: MTPD 4 jam menurunkan RTO sistem 120 menit. Ketergantungan dapat mengalahkan target.
- Strategi dua jalur. Opsi B Rp200 juta lebih mahal per tahun untuk memenuhi batas 2 persen.
- Krisis Siber ditetapkan Presiden. Pemulihan tidak menggeser batas 3×24 jam.
- Layanan pulih ketika pasien dapat dilayani secara aman pada kapasitas yang disepakati.

Latihan

1. Jelaskan perbedaan RTO dan RPO dengan contoh layanan farmasi rumah sakit.
2. Mengapa RTO untuk semua layanan tidak boleh ditetapkan nol? Kaitkan dengan biaya dan *risk appetite*.
3. Rancang tiga pertanyaan keputusan yang harus dijawab direksi dalam latihan *tabletop* serangan *ransomware*.

Gunakan tabel contoh dan lembar hasil pada modul untuk membela alasan.